

PROJECT 3 OF 8 — PART 1: INCIDENT DEEP DIVE

COLONIAL PIPELINE RANSOMWARE (2021)

Ransomware · No MFA · East Coast Fuel Crisis · \$4.4M Ransom Paid

 **THIS PROJECT:** Understand what happened, map the attack, research the CVE. This project ends with a CVE Research Worksheet (50 points).

 **CVE / ADVISORY:** No CVE — stolen VPN password, no MFA. Research CISA Alert AA21-131A (DarkSide Ransomware).

INCIDENT OVERVIEW

On May 7, 2021, Colonial Pipeline — operator of the largest fuel pipeline in the United States supplying 45% of the East Coast's fuel — suffered a ransomware attack by the DarkSide criminal group. Attackers accessed the network using a single compromised VPN password found on the dark web. There was NO multifactor authentication on that account. Colonial proactively shut down pipeline operations fearing ransomware would spread to OT systems, triggering fuel shortages across 17 states. Colonial paid \$4.4 million in Bitcoin ransom within hours. The FBI later recovered \$2.3 million.

KEY FACTS AT A GLANCE

- Entry point: ONE compromised VPN password found on the dark web — NO multifactor authentication
- Attacker group: DarkSide (ransomware-as-a-service criminal organization)
- 100GB of data exfiltrated BEFORE ransomware was deployed (double-extortion)
- Colonial proactively shut down 5,500 miles of pipeline — OT systems were NOT infected
- Fuel shortages across 17 states — national emergency declared by President Biden
- \$4.4 million Bitcoin ransom paid; FBI later recovered \$2.3 million of it
- DarkSide shut down operations shortly after the attack

PROJECT 3 · DAY 1

MONDAY — INCIDENT INTRODUCTION + CIA TRIAD

1-2 HRS

 **OBJECTIVE:** Students understand the Colonial Pipeline Ransomware at a high level and apply the CIA Triad to identify which pillars were violated and how.

PROJECT 3 · DAY 2

TUESDAY — CYBER KILL CHAIN — ALL 7 PHASES

1-2 HRS

 **OBJECTIVE:** Students map the complete attack through all 7 Kill Chain phases using specific incident evidence.

PROJECT 3 · DAY 3

WEDNESDAY — MITRE ATT&CK — HANDS-ON LAB

1-2 HRS

 **OBJECTIVE:** Students identify specific ATT&CK techniques, navigate attack.mitre.org, and explain each technique in plain English.

PROJECT 3 · DAY 4

**THURSDAY — CVE RESEARCH LAB + WORKSHEET
SUBMISSION (50 PTS)**

1-2 HRS

 **OBJECTIVE:** Students research the CVE or CISA advisory, build the incident timeline, finalize and submit the CVE Research Worksheet.

 **DUE:** Thursday of this project. Submit to your instructor.

[10 pts] What is the CVE number and CVSS score for this incident? If no CVE exists, what CISA advisory or identifier applies? What does the CVSS score (or the absence of a CVE) tell you about the nature of this vulnerability?

[10 pts] Describe the vulnerability or weakness in your own words — plain English, no jargon. A non-technical reader should completely understand what went wrong.

[10 pts] When was the official patch or fix released? How much time passed between the fix being available and the breach occurring? What does that timeline tell you about the organization's security practices?

[10 pts] Who was involved in containing this incident? What specific actions were taken? How long did full containment take?

[10 pts] List your 3 most critical "From Here On Out" recommendations for any organization that uses similar technology. For each, explain specifically WHY it would have prevented or reduced this breach.

REFERENCES & RESOURCES

- CISA Alert AA21-131A: "DarkSide Ransomware: Best Practices" — [cisa.gov](https://www.cisa.gov)
- U.S. Senate Homeland Security Committee: Colonial Pipeline CEO Testimony (June 8, 2021)
- DOJ Press Release: "Department of Justice Seizes \$2.3 Million in Cryptocurrency Paid to DarkSide" (June 7, 2021)
- TSA Pipeline Security Directive SD-02B — [tsa.gov](https://www.tsa.gov)
- MITRE ATT&CK: attack.mitre.org — search T1078, T1486, T1490
- CISA Ransomware Guide: [cisa.gov/ransomware](https://www.cisa.gov/ransomware)

